Rapport 4.1

Hardening & Vulnerability Management

1. Introduction et Objectif

Ce document présente les résultats du scan de vulnérabilités réalisé à l'aide de l'outil Nessus Essentials. L'objectif est d'identifier les failles de sécurité, les erreurs de configuration et les services exposés sur les machines testées.

Cibles auditées :

- Machine Ubuntu : 192.168.56.10
- Machine Windows : 192.168.56.20

2. Installation et Mise en œuvre

L'installation a été effectuée sur Kali Linux via les commandes suivantes :

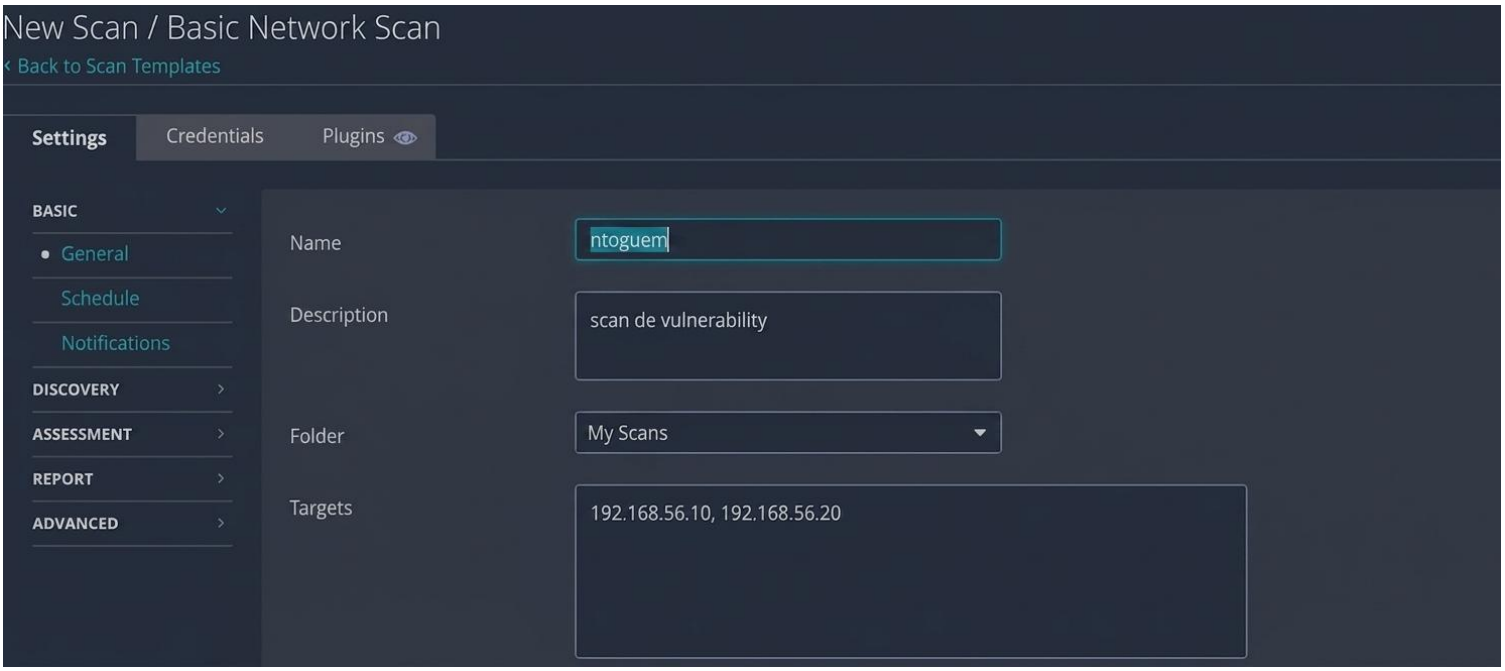
 sudo dpkg -i Nessus-.deb*

sudo systemctl start nessusd

une fois installé et activé, on accède à l'interface d gestion via https://localhost:8834 saisie dans le navigateur, puis on se connecte avec nos identifiant.

3. Méthodologie du Scan

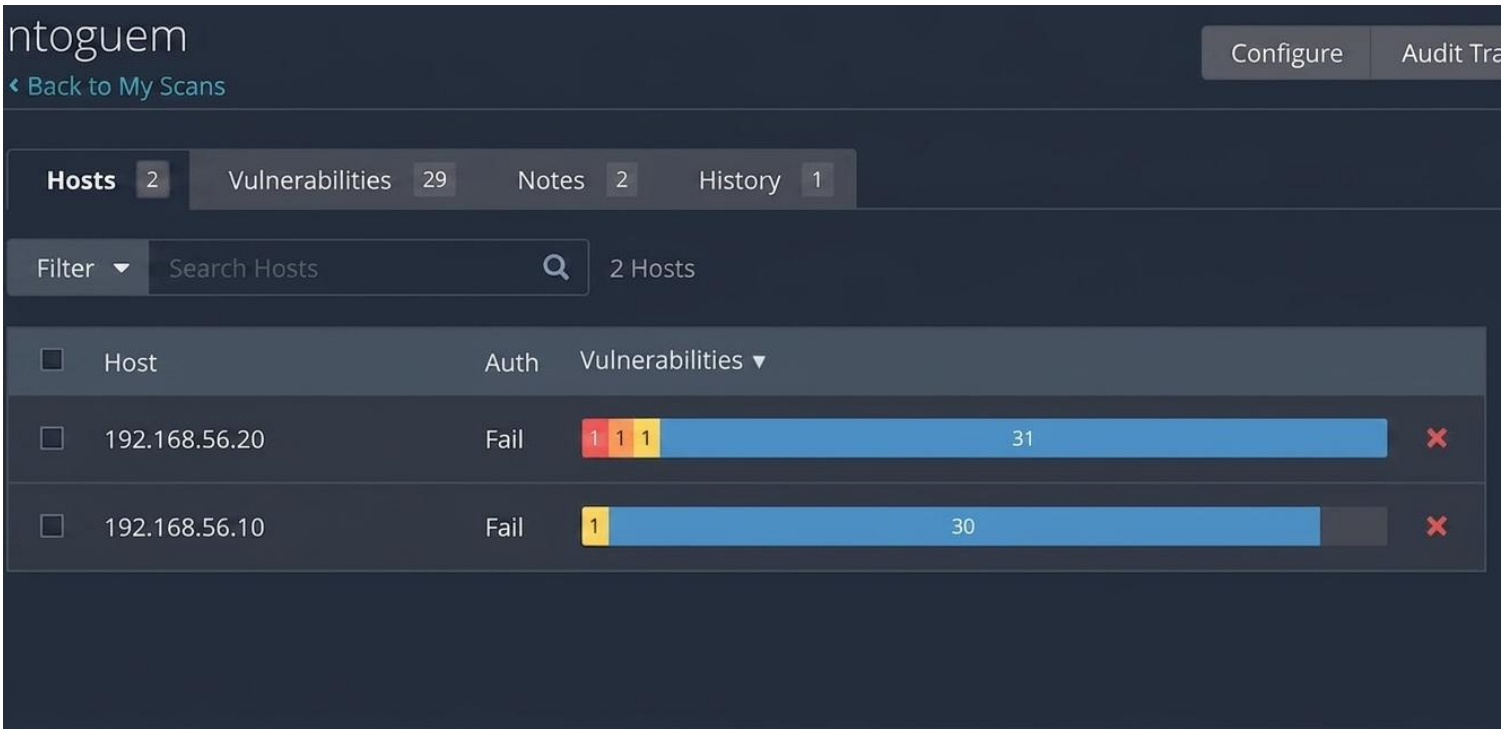
Pour scanné, on tape suit **new scan** et on remplit comme indiquer sur l'image ci-dessous :



Nous avons utilisé le modèle "**Basic Network Scan**". Ce scan permet de découvrir les vulnérabilités système courantes en interrogeant les services actifs sur les ports distants.

4. Analyse des Résultats

Nessus catégorise les vulnérabilités par niveau de sévérité (Critique, Haute, Moyenne, Faible, Info).



On peut voir sur cette image qu'en ce qui concerne l'hôte 192.168.56.20 (Windows) on a une vulnérabilité critique, 0 haute, une moyenne, une faible et 31 infos. Par contre pour l'hôte 192.168.56.10(Ubuntu) on a une vulnérabilité faible et 30 infos.

5. Détail d'une Vulnérabilité Majeure

Analyse d'une faille critique identifiée sur windows :

- Nom MS7-010
- Score CVSS : 8.8
- Impact : cette vulnérabilité pr2sente sur le protocole SMBv1 permet d'exécuter du code à distance sur une machine ce qui pourrait permettre à l'attaquant de faire un vol de donné ou un déni de service.

ntoguem / Plugin #97833

‹ Back to Vulnerabilities

Vulnerabilities 18

HIGH MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPI...

Description

The remote Windows host is affected by the following vulnerabilities :

- Multiple remote code execution vulnerabilities exist in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit these vulnerabilities, via a specially crafted packet, to execute arbitrary code. (CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0148)

- An information disclosure vulnerability exists in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit this, via a specially crafted packet, to disclose sensitive information. (CVE-2017-0147)

ETERNALBLUE, ETERNALCHAMPION, ETERNALROMANCE, and ETERNALSYNERGY are four of multiple Equation Group vulnerabilities and exploits disclosed on 2017/04/14 by a group known as the Shadow Brokers. WannaCry / WannaCrypt is a ransomware program utilizing the ETERNALBLUE exploit, and EternalRocks is a worm that utilizes seven Equation Group vulnerabilities. Petya is a ransomware program that first utilizes CVE-2017-0199, a vulnerability in Microsoft Office, and then spreads via ETERNALBLUE.

Solution

Microsoft has released a set of patches for Windows Vista, 2008, 7, 2008 R2, 2012, 8.1, RT 8.1, 2012 R2, 10, and 2016. Microsoft has also released emergency patches for Windows operating systems that are no longer supported, including Windows XP, 2003, and 8.